

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

COURSE: GRC205 – INCIDENT MANAGEMENT AND BUSINESS CONTINUITY

MODULE: CRISIS COMMUNICATION AND STAKEHOLDER MANAGEMENT

LAB ASSIGNMENT: CRISIS COMMUNICATION SIMULATION

MODE OF ASSESSMENT: PRACTICAL DATA BREACH RESPONSE

DATE OF SUBMISSION: 15TH JANUARY, 2026.

GROUP 4



HEALTHCONNECT



Table of Contents

SCENARIO BACKGROUND.....	3
1.1 Communication Strategy Memo.....	7
2.1 Employee Notification Email (From the CEO to All Employees).....	12
2.2 Manager Talking Points (For Team Meetings).....	16
3.1 Customer Notification Email.....	21
3.2 Customer FAQ Document.....	25
3.3 Decision Rationale Memo.....	27
4.1 Media Response Statement.....	31
5.1 Social Media Response Strategy.....	35
5.2 Social Media Posts.....	37
6.1 Strategic Communication Memo.....	39
6.2 Investor Communication.....	44
7.1 Press Release: (HIPAA Media Notification).....	45
8.1 Crisis Response Memo.....	49
8.2 Customer Retention Communication.....	53
9.1 CEO Town Hall Talking Points.....	55
9.2 Anticipated Q&A.....	61
10.1 Public Statement on Investigation.....	65
11.1 Communication Strategy Memo.....	68
11.2 Recovery Communication.....	70
12.1 Crisis Communication After-Action Report.....	71
12.2 Board Presentation Outline.....	74
References.....	76



SCENARIO BACKGROUND

Organization Profile: HealthConnect

HealthConnect is a rapidly growing healthcare technology company founded in 2015 and headquartered in Boston, Massachusetts. The company provides a cloud-based electronic health records (EHR) platform used by 850 healthcare providers, including hospitals, clinics, and private practices across 35 states. HealthConnect's platform stores and manages protected health information (PHI) for approximately 12 million patients.

Business Model:

- Software-as-a-Service (SaaS) EHR platform
- Annual subscription model for healthcare providers
- Average contract value: \$75,000 per provider per year
- Annual recurring revenue: \$64 million
- 420 employees (180 engineering, 120 customer success, 60 sales, 60 corporate functions)
- Venture-backed, with \$120 million raised across four funding rounds
- Planning IPO in 18 months

Technology Infrastructure:

- Cloud-based platform hosted on AWS
- Multi-tenant architecture with data segregation
- SOC 2 Type II certified
- HIPAA compliant with annual audits
- 99.9% uptime SLA commitment

Regulatory Environment: HealthConnect operates in one of the most heavily regulated industries. The company must comply with HIPAA privacy and security rules, state data breach notification laws, and contractual obligations to healthcare provider customers. Data breaches



involving PHI trigger mandatory notifications to patients, the Department of Health and Human Services (HHS), and potentially the media if affecting more than 500 individuals.

Competitive Landscape: HealthConnect competes with established EHR vendors like Epic, Cerner, and Athenahealth, as well as newer cloud-based competitors. The company's competitive advantage is ease of use, a modern interface, and lower cost. However, any perception of security weakness could be devastating to customer trust and the sales pipeline.

Your Role: Vice President of Communications

You are the Vice President of Communications at HealthConnect, reporting directly to the CEO. You have been in this role for 18 months and successfully managed several product launches and funding announcements. This is your first major crisis.

Your responsibilities include:

- Leading all crisis communication activities
- Managing internal and external communications
- Coordinating with legal, security, and operations teams
- Serving as primary media contact and spokesperson
- Advising the CEO and executive team on communication strategy
- Managing social media and digital communication channels

You have a team of three communications professionals:

- **Director of Internal Communications** - Manages employee communication
- **Communications Manager** - Handles media relations and press releases



- **Social Media Manager** - Manages all social media channels

The Crisis: Data Breach Discovery

Day 1 - Monday, 6:45 AM EST

You receive an urgent call from the Chief Information Security Officer (CISO) while getting ready for work. She informs you that the security team detected suspicious activity on the HealthConnect platform overnight. Initial investigation suggests unauthorized access to the production database. The incident response team has been activated and is conducting a forensic analysis.

Initial Information (6:45 AM):

- Suspicious database queries detected at 2:30 AM
- Unauthorized access from an external IP address confirmed
- Scope of data access unknown at this time
- No evidence of data exfiltration yet (still investigating)
- Production systems remain operational
- Incident response team activated at 5:00 AM
- The CEO, CTO, and General Counsel have been notified
- Emergency executive meeting scheduled for 7:30 AM

The CISO tells you to prepare for potential data breach notification requirements and to be ready to communicate with stakeholders. She emphasizes that the situation is still being investigated and information is preliminary.

You arrive at the office at 7:15 AM. The executive team meeting is in 15 minutes.



Simulation Structure

This simulation unfolds over 72 hours (3 days) with multiple decision points, injects, and deliverables. You will receive new information throughout the simulation that requires you to adapt your communication strategy and respond to emerging challenges.

Timeline Overview

Day 1 (Monday): Crisis discovery, initial assessment, stakeholder notification, and first public communication

Day 2 (Tuesday): Scope confirmation, regulatory notifications, media management, and customer communication

Day 3 (Wednesday): Ongoing updates, employee town hall, lessons learned initiation, and recovery communication

Simulation Mechanics

You will respond to 12 decision points throughout the simulation. At each decision point, you will:

- 1 Receive new information (inject)
- 2 Make decisions about communication strategy and actions
- 3 Draft required communications
- 4 Document your decision rationale
- 5 Manage stakeholder reactions

**Decision Point 1: Executive Meeting and Initial Assessment (Day 1, 7:30 AM)**

You attend the emergency executive meeting. The CISO provides an update:

- Unauthorized access confirmed through compromised API credentials
- Attacker accessed the production database for approximately 4 hours (2:30 AM - 6:30 AM)
- Database logs show queries against the patient records table
- An estimated 50,000-150,000 patient records potentially accessed (exact number still being determined)
- Data accessed includes: names, dates of birth, Social Security numbers, addresses, phone numbers, email addresses, medical record numbers, diagnoses, and treatment information
- No evidence of data exfiltration yet, but forensic analysis is ongoing
- Vulnerability has been patched, compromised credentials revoked
- Systems remain operational

The CEO asks you: "What do we need to communicate, to whom, and when?"

The General Counsel reminds everyone that HIPAA requires notification to affected individuals within 60 days, but many state laws require notification "without unreasonable delay," which courts have interpreted as days or weeks, not months.



1.1 Communication Strategy Memo

TO: Executive Team and CEO.

FROM: Communications VP.

DATE: Monday, Day 1.

Subject: Crisis Communication Plan- "Project Integrity" (Data Security Incident)

Executive Summary.

A confirmed unauthorized access incident involving between 50,000 and 150,000 patient records is presently under our management. HealthConnect is in a high-risk regulatory and reputational position due to the type of data accessed, including SSNs and medical diagnoses, even though the vulnerability has been patched. In order to protect our impending IPO trajectory and maintain the confidence of our 850 healthcare provider partners, this memo lays out a proactive, transparent focused approach.

SCCT Framework and Situational Analysis.

According to the Situational Crisis Communication Theory (SCCT) framework, if carelessness is suspected, we classify this as a Victim-to-Accidental Crisis that is evolving into a Preventable Crisis.

- A data breach (technical error/external intrusion) is a type of crisis.
- Medium in terms of responsibility attribution. Even though we are the targets of an attack, using hacked API credentials could be seen as a security flaw.
- Response: Diminish and Rebuild is the response strategy. The victim narrative must be minimized in favor of bolstering (reminding stakeholders of our SOC 2 Type II status and HIPAA compliance while accepting full responsibility for the correction).

Prioritization and Notification Order for Stakeholders.

1. The concentric circle notification model will be used.



2. Internal (Workers): To maintain a cohesive front and stop leaks.
3. Board of Directors/Investors: To safeguard our \$120 million venture capital funding.
4. Key Partners/Major Hospital Systems: Direct communication with the accounts that generate the most revenue.
5. State-level notifications and HIPAA/HHS are regulatory bodies.
6. All 850 healthcare providers make up the general customer base.
7. Public/Media: Restricted press release to control the story before it spreads.

Key Messages/ Points.

- Security First: We patched the vulnerability and immediately activated our incident response team upon discovery.
- Openness: We are collaborating with forensic specialists to ascertain the precise extent of the impact.
- Promise: We are taking every step to support affected providers, and patient privacy is our cornerstone.

Coordination and Risk Reduction.

- Legal: General Counsel must review all correspondence to make sure the attorney-client privilege is not waived during the forensic investigation.
- Security: To prevent over-promising, data security communications will only contain information verified by the CISO.
- Risks:
 - Early Disclosure: There is a chance that the figures will be incorrect.
 - Delayed Disclosure: Possible cover-up charges and regulatory fines.



- Trade-off: In order to preserve HealthConnect’s “Ease of Use and Trust” competitive advantage, we prioritize early transparency over complete certainty.

1.2 Initial Stakeholder Notification Plan (Day 1).

Thorough stakeholder messaging.

Stakeholders Group	Period	Channel	Main Message	Delivered By
All Employees	Monday, 9:00am	Slack or Internal email (Emergency All Hands) and Virtual	A security incident has been identified and is being handled. For all media inquiries please contact the communications team.	CEO
Executive Leadership	Monday, 10: 30am	Private Briefing Call on a secure line.	An update on the state of forensics and patching.	CISO or VP of Comms
Top 20 Clients	Monday, 1:10pm	Direct phone call	An assurance that we are looking into scope and that their data segregation is intact.	Head of Customer Success
Regulators (HHS)	Monday, 3:00pm	Formal Portal or Legal filing	First notification of a possible PHI breach as mandated by law.	General Counsel/ Lawyer
Health Providers	Monday, 5:00pm	Secure Customer Portal	General guidance on unauthorized access and the measures	VP of Customer Success



			implemented to protect the API.	
Media / General Public	Reactive	Email/ Website/Newsroom	A security incident was found by HealthConnect. The platform is secured and a thorough investigation is underway.	VP of Comms (Spokesperson)

Detailed Stakeholder Messaging

Workers (420 in total).

- The main objectives are leak prevention and internal alignment.
- Main Takeaway: A security incident has occurred. The platform has been protected by the engineering team. Do not answer questions from the media; instead, direct them to the Communications Team.
- Delivery: A Fact Sheet for Customer Success teams is given after a live Zoom call.

Customers of Healthcare Providers (850 entities).

- Main Objective: Reduce attrition and offer useful information for their own HIPAA compliance.
- Key Takeaway: Unauthorized access to a database holding patient records was discovered. As a partner in patient care we are alerting you right away while we continue to determine the precise scope.
- Delivery: Direct emails sent to the primary account contacts.

HHS and State AGs are regulatory bodies.



- The main objective is to demonstrate good faith efforts and to comply with the law. • Key Message: Notification of a PHI breach involving between 50000 and 150000 records. An investigation is still underway.
- Delivery: Consistent regulatory documents.

Media and social media.

- Story control is the main objective.
- Key Takeaway: HealthConnect has found and fixed a security flaw. We are collaborating with forensic specialists and law enforcement to safeguard our users.
- Delivery: One holding post on LinkedIn/X and a reactive press release.

2.1 Employee Notification Email (From the CEO to All Employees)**CONFIDENTIAL – FOR INTERNAL DISTRIBUTION ONLY**

Subject: Important Security Update – Immediate Action Required

From: Sarah Chen, Chief Executive Officer

To: All HealthConnect Employees

Date: [Current Date] 11:30 AM EST

Dear Team, I am writing to inform you of a serious security incident that has affected our platform and requires our immediate and coordinated response. I want to share what we know, what we're doing about it, and what this means for each of you.

What Happened

Early this morning, our security team discovered unauthorized access to our production database. After an intensive forensic investigation, we have confirmed that an attacker gained access through compromised API credentials and accessed patient records for approximately 4 hours between 2:30 AM and 6:30 AM today.

**What We Know**

- 127,000 patient records were accessed and downloaded by the attacker.
- The accessed data includes full protected health information (PHI): names, dates of birth, Social Security numbers, addresses, phone numbers, email addresses, medical record numbers, diagnoses, and treatment information.
- 243 of our 850 healthcare provider customers are affected.
- The largest affected customer is a regional hospital system with 45,000 patient records accessed.
- The smallest affected customers are individual practices with 50–200 records accessed.
- We have evidence that data was downloaded from our systems.

What We Don't Yet Know

Our investigation continues, and we are working to determine:

- The exact identity of the attacker and their motivations.
- Whether the stolen data has been shared, sold, or published anywhere.
- If any other systems were compromised beyond the patient records database.
- The full timeline of how the attacker initially gained access.

What We're Doing

We are taking comprehensive action:

- Our incident response team is working around the clock with leading cybersecurity experts.
- We have immediately secured the compromised access point and implemented additional security measures.
- We are cooperating fully with federal law enforcement agencies.
- We will be notifying affected patients as required by law.



- We must first notify our healthcare provider customers so they can prepare for patient inquiries.
- We will be filing required notifications with the Department of Health and Human Services (HHS).
- We are conducting a complete security review of all our systems.

Your Role and Responsibilities

This is a critical time for our company, and I need your complete support:

Media and Customer Inquiries:

- Direct all media inquiries immediately to our Communications team at [email] or [phone].

For customer inquiries:

- Listen with empathy and concern.
- Say: “We are taking this incident very seriously and are working with experts to investigate and respond appropriately. We will be providing detailed information to affected customers today.”
- Do NOT speculate about causes, timeline, or potential impacts
- Escalate immediately to your manager or the customer success team.

Confidentiality:

- This information is strictly confidential until we make public announcements.
- Do not discuss details with family, friends, or anyone outside the company.
- Do not post anything on social media about this incident.
- Speculation or unauthorized sharing of information could harm our customers and our investigation.

**Business Continuity:**

- Our platform is secure and operational for customer use.
- Continue serving our customers with the same dedication and professionalism.
- Your managers will provide specific guidance for your teams.

What This Means for Health Connect

I won't minimize the seriousness of this situation. We handle some of the most sensitive data in healthcare, and our customers and their patients trust us to protect it. We have let them down, and we will do everything in our power to make this right. However,

I have complete confidence in this team and our ability to manage this crisis professionally and effectively. We have strong relationships with our customers built over years of reliable service. We have the resources and expertise to respond appropriately. Most importantly, we have a team of dedicated professionals who care deeply about our mission.

Support and Questions

I understand this is stressful news. If you have questions or concerns:

- Contact your direct manager for immediate questions.
- HR is available for employee support at [email] or [phone].
- I will be hosting an all-hands meeting tomorrow at 10 AM EST to provide updates.
- My office door is always open for any of you who need to speak with me directly.

Moving Forward

We will get through this together. Our response in the coming days and weeks will define who we are as a company. I need your professionalism, your discretion, and your continued

Crisis Communication and Stakeholder Management

Compiled by: Group 4

Date: 15 January 2026



commitment to our customers. I will provide regular updates as our investigation progresses. Thank you for your dedication during this challenging time.

Sincerely,

[Name],

Chief Executive Officer,

HealthConnect

Direct : (555) 123-4567

Email: group4@healthconnect.com

This communication contains confidential information. Distribution is limited to HealthConnect employees only.

2.2 Manager Talking Points (For Team Meetings)

CONFIDENTIAL – MANAGER TALKING POINTS

HealthConnect Security Incident Response

Day 1 – Team Meeting Guide

Key Facts about the Incident

- A security breach was discovered at 6:45 AM today by our security team.
- Unauthorized access occurred between 2:30 AM – 6:30 AM via compromised API credentials.
- 127,000 patient records were accessed and downloaded by the attacker.
- Full PHI exposed: names, DOB, SSN, addresses, phone, email, medical record numbers, diagnoses, and treatments.
- 243 out of our 850 healthcare provider customers are affected.



- Range: Largest customer (regional hospital) 45,000 records, smallest practices 50–200 records.
- Evidence confirms that data was exfiltrated from our systems.
- The platform is secure and operational for customer use.

Answers to Anticipated Employee Questions

Question	Suggested Answer
How did this happen?	The attacker used compromised API credentials to gain access. Our investigation is ongoing to determine exactly how those credentials were obtained. We're working with cybersecurity experts to understand the full timeline.
Are we going to lose customers?	This is naturally a concern. We're being transparent with our customers and taking full responsibility. Our focus is on making this right and demonstrating our commitment to security going forward.
Is my job safe?	The company is focused on managing this crisis responsibly. We need everyone working together right now. If you have specific concerns, please speak with me or HR privately.



What about the customers in contract renewal?	We're aware of the timing challenges with some customers. Our priority is honest communication and demonstrating our response capabilities. The sales and customer success teams are handling these situations directly.
Can I tell my family what happened?	No. This information is confidential until we make official announcements. Unauthorized disclosure could harm our investigation and legal position.
When will this be public?	We must notify affected customers first, then patients, then file with HHS. Media coverage is likely once notifications begin. Communications will handle all external messaging.

Business Continuity Guidance

- Platform operations continue normally – no service interruption.
- Customer support should expect increased inquiries starting today.
- All projects and deadlines remain in effect unless specifically modified.
- Focus on delivering excellent service to demonstrate our ongoing commitment.
- Document any customer concerns or feedback immediately.
- Escalate any unusual customer requests or concerns immediately.



Supporting Anxious Team Members

Signs to watch for:

- Difficulty concentrating or making decisions
- Excessive worry about job security or the company's future
- Reluctance to interact with customers
- Physical symptoms of stress (headaches, fatigue)

How to help:

- Acknowledge that stress is normal in this situation.
- Remind them that the company is taking proper action.
- Focus on what we can control – our response and service quality.
- Encourage use of EAP services if available.
- Be available for one-on-one conversations.
- Reinforce that we have experienced leadership managing this crisis.

Escalation Procedures for Customer Inquiries

Escalate Immediately If:

- The customer demands detailed information about the breach.
- The customer threatens to cancel the contract or withhold payment.
- The customer asks about specific patient records or data.
- Customer requests to speak with executives.
- The media identifies itself or asks questions.
- Anyone asks about legal liability or lawsuits.

Escalation Contacts:



- Customer Success Team: [phone/email] – for customer concerns
- Communications Team: [phone/email] – for media inquiries
- Legal Department: [phone/email] – for legal questions
- IT Security: [phone/email] – for technical questions
- Manager Hotline: [phone] – for urgent management questions

Your Immediate Action Items**Before your team meeting:**

- Review the CEO's email thoroughly.
- Prepare to answer questions calmly and factually.
- Have escalation contacts readily available.
- Clear your schedule for potential follow-up conversations.

During the team meeting:

- Read key portions of the CEO email if helpful.
- Address questions directly using talking points.
- Take notes on team concerns for follow-up.
- Reinforce the importance of confidentiality.
- End with confidence in our team and company.

After team meeting:

- Follow up privately with any team members showing high stress.
- Report significant concerns to the management hotline.
- Continue normal supervision while being available for questions.
- Document any customer feedback or concerns immediately.

Key Messages to Reinforce:



- We take full responsibility and are responding comprehensively.
- Our priority is to make this right for the affected patients and customers.
- The platform is secure and operational.
- We have experienced leadership and strong resources to manage this.
- Every team member's professionalism is critical to our response.
- Confidentiality protects our investigation and legal position.
- We will get through this together by focusing on excellent service

Summary

- **Employee Notification Email:** Clearly communicates the breach, what is known/unknown, actions being taken, guidance for inquiries, confidentiality, confidence in the team, and contact info.
- **Manager Talking Points:** Equips managers with facts, answers to likely questions, business continuity guidance, support for anxious staff, and clear escalation procedures.

Your leadership and professionalism are essential as we work together to challenge.

3.1 Customer Notification Email

To: Primary Administrative Contact / HIPAA Compliance Officer

From: HealthConnect Executive Leadership Team

Date: Monday, Day 1: 11:30 AM EST

Subject: Important Security Incident Notification Regarding Your HealthConnect Account

Dear Valued Partner,

At HealthConnect, we hold the trust you place in us to safeguard your patients' Protected Health Information (PHI) as our highest priority. We are writing to formally and transparently

Crisis Communication and Stakeholder Management

Complied by: Group 4

Date: 15 January 2026



notify you of a security incident that has impacted a subset of the patient records managed within your organization's HealthConnect Electronic Health Record (EHR) platform.

What Happened

On Monday, January 12, at approximately 2:30 AM EST, our security monitoring systems detected unauthorized access to our production database. Our incident response team immediately initiated a forensic investigation, which confirmed that an unauthorized third party gained access to our systems via compromised API credentials.

The unauthorized access lasted for approximately four hours before the credentials were revoked, and the vulnerability was patched. Unfortunately, our investigation has confirmed that database query results were exfiltrated during this window.

Information Involved and Scope of Exposure

Based on a comprehensive forensic review of the database logs, we have determined that the following types of patient data were accessed:

- Full names and dates of birth
- Social Security numbers and home addresses
- Medical record numbers, diagnoses, and treatment information

Specific Impact to Your Organization:

According to our records, approximately 45,000 patient records associated with your specific organization were included in the data accessed during this incident. We are currently finalizing the specific list of affected individuals for your records to assist in your internal reconciliation.



Our Response Actions

Immediately upon discovery, HealthConnect took the following steps to secure the environment and protect your data:

Containment: We revoked the compromised API credentials and applied a security patch to the affected interface within hours of detection.

Forensics: We engaged leading external cybersecurity experts to conduct a deep-dive forensic analysis and ensure no further persistence exists in our environment.

Law Enforcement & Regulatory: We are in the process of notifying the Department of Health and Human Services (HHS) and relevant law enforcement agencies.

Security Hardening: We are implementing enhanced multi-factor authentication requirements for all API access and increasing our real-time monitoring frequency.

Next Steps and Patient Notification

We recognize that you have legal and ethical obligations to your patients. Under HIPAA and relevant state laws, HealthConnect will work closely with your organization to support the timely notification of affected individuals.

1. Patient Letters: Within the coming days, HealthConnect will begin mailing formal notification letters to all affected patients. These letters will explain the incident and provide clear instructions on how they can protect themselves.

2. Protective Services: To support your patients, HealthConnect will provide two years of complimentary credit monitoring and identity theft protection services to every individual whose Social Security number was compromised.



3. Dedicated Support: We are establishing a dedicated patient call center to handle inquiries, which will be live by the time patient letters arrive.

Resources and Support for Your Team

We understand that your patients may contact your offices directly before receiving our formal letter. To help your staff manage these inquiries consistently and accurately, we have attached a Customer FAQ Document and Staff Talking Points to this email.

We recommend that your internal teams

- Review the attached FAQ to prepare your front-office staff.
- Direct any complex patient questions to our dedicated Provider Support Line listed below.

Our Commitment to You

We deeply regret that this incident occurred. While we pride ourselves on our modern security infrastructure, this event has shown us that we must do more. We are taking full accountability for this breach and are committed to working tirelessly to regain your confidence.

We are also conducting a comprehensive review of our security governance, risk management, and monitoring controls to prevent similar incidents in the future.

We will provide you with regular updates as more information becomes available. If you have immediate questions, please contact our Provider Response Team at (800) 555-0199 or via the secure partner portal.

Sincerely,

The HealthConnect Leadership Team



3.2 Customer FAQ Document

HealthConnect Security Incident: Healthcare Provider FAQ

Document Date: 12/01/2026

Subject: Guidance and Frequently Asked Questions regarding the unauthorized access to patient data.

Overview

HealthConnect is committed to transparency and maintaining the trust of our healthcare provider partners. We understand the seriousness of this incident and are providing this document to assist your organization in managing patient communications and fulfilling regulatory obligations.

1. What happened and how did it happen? On Monday, Jan. 1, at approximately 2:30 AM EST, HealthConnect's security team detected suspicious database queries. Our investigation confirmed that an unauthorized external party gained access to our production environment. This access was achieved through the compromise of API credentials. We immediately activated our incident response protocols, revoked the affected credentials, and patched the vulnerability to prevent further unauthorized access.

2. What data was accessed? Forensic analysis confirmed that the unauthorized party downloaded database query results containing Protected Health Information (PHI). The data accessed included:

- Full names and dates of birth.
- Social Security numbers and addresses.
- Phone numbers and email addresses.
- Medical record numbers, diagnoses, and treatment information.



3. How many of our patients are affected? Across our entire platform, 127,000 patient records were accessed, involving 243 healthcare provider customers. We have provided your organization with a specific list of the patients within your practice or facility who were impacted by this breach.

4. What is HealthConnect doing about this? HealthConnect is taking several immediate and long-term actions:

Remediation: We have hardened our API security and implemented enhanced monitoring across all cloud infrastructure.

Investigation: We are working with third-party digital forensics experts to conduct a comprehensive review of the incident.

Authorities: We have notified federal law enforcement and are cooperating fully with the Department of Health and Human Services (HHS) Office for Civil Rights.

5. What are our obligations to notify patients? Under the HIPAA Breach Notification Rule and various state data breach notification laws, there is a legal requirement to notify affected individuals without unreasonable delay. As the business associate, HealthConnect is coordinating with you to ensure all patients are notified in accordance with these regulations.

6. Will HealthConnect help with patient notification? Yes. To ease the administrative burden on your staff, HealthConnect is managing the direct mailing of formal notification letters to all 127,000 affected patients. These letters will explain the incident, the specific data involved, and the protections we are providing.

7. What should we tell patients who call us? If a patient contacts your office, we recommend your staff use the following holding statement:



"We have been informed by our technology partner, HealthConnect, that they experienced a security incident that may have affected some patient records. HealthConnect is currently mailing formal notification letters to all individuals involved. These letters include detailed information and a dedicated support line for any questions you may have regarding your data."

8. How can we be confident this won't happen again? HealthConnect is treating this as a preventable crisis and taking full accountability for the failure in credential management. We are implementing a mandatory multi-factor authentication requirement for all API access and have initiated a complete audit of our security protocols to identify and close any other potential gaps.

9. What support is HealthConnect providing? To support the affected individuals, HealthConnect is offering:

- Two years of complimentary credit monitoring and identity theft protection services.
- A dedicated toll-free call center to answer patient questions.
- A specialized support team for our healthcare provider partners to assist with any technical or administrative concerns.

10. Will there be any service disruption? No. Our production systems remain fully operational, and the vulnerability has been closed. You may continue to use the HealthConnect EHR platform for patient care without interruption.

Contact Information

For further questions or technical assistance, please contact your dedicated Account Manager or reach out to our Crisis Response Team at help@HealthConnect.com



3.3 Decision Rationale Memo

Why We Chose This Timing for Customer Notification

We decided to notify our healthcare customers as soon as we had credible, verified information, even though the investigation was still ongoing. By late morning on Day 1, we knew that unauthorized access had occurred and that sensitive patient information *may* have been exposed. Waiting longer would have increased customer anxiety, risked rumors spreading, and could have violated state breach notification laws that require notification “without unreasonable delay.”

Although HIPAA allows up to 60 days to notify affected individuals, many U.S. states expect companies to act within days, not weeks. Notifying customers at noon allowed them to begin their own internal assessments, prepare patient communications if needed, and hear the news directly from us instead of the media.

Balancing Legal Requirements, Customer Relationships, and Transparency

We carefully balanced three key factors:

- **Legal compliance:**

We avoided making final claims about the number of affected records while still meeting early notification expectations. Our message used accurate language such as “*potentially accessed*” rather than “*confirmed stolen*.”

- **Customer trust:**

Our customers are healthcare providers responsible for patient care and privacy. Early notification showed respect, accountability, and partnership rather than secrecy.

- **Transparency without speculation:**

We shared what we knew, clearly stated what we were still investigating, and committed to regular updates. This avoided misleading statements while maintaining credibility.

**SCCT Response Strategy Applied**

We applied the Situational Crisis Communication Theory (SCCT): Rebuild Strategy - Corrective Action with Empathy.

This was appropriate because:

- The incident involved sensitive patient data.
- Even though the attack was external, customers still expect HealthConnect to protect their data.
- Trust is critical in healthcare.
- Our communication therefore:
 - Acknowledged concern and impact
 - Took responsibility for managing the incident
 - Explained corrective actions already taken (credentials revoked, vulnerability patched)
 - Reassured customers that system security was being strengthened

We avoided denial or minimizing the issue, which could have severely damaged trust.

Risks Considered and How We Mitigated Them**Key risks included:****1. Releasing incomplete or incorrect information**

Mitigation: We clearly labeled information as preliminary and committed to updates.

2. Legal and regulatory exposure

Mitigation: All communications were reviewed by Legal to ensure compliance and careful wording.

3. Media leaks before customers were informed

Mitigation: We prioritized customer notification before any public statement.



4. Customer panic or contract cancellations

Mitigation: We used calm, empathetic language, explained system stability, and provided FAQs and support contacts.

Overall, early, honest communication reduced long-term reputational and regulatory risk.

Decision Point 4: Media Inquiry Response (Day 1, 2:30 PM)

(Healthcare IT News – 2:30 PM Day 1)

Should We Confirm or Decline to Comment?

We should confirm the incident, but effectively control the narrative.

Declining to comment would:

- Appear evasive
- Increase suspicion
- Allow unverified sources to define the story

Since customers have already been notified and information is likely to become public, a controlled confirmation is the least damaging option.

What We Say (Approved Media Holding Statement)

Recommended Response to Reporter:

Earlier today, we identified and contained unauthorized access to a portion of our platform. Our investigation is ongoing, but out of an abundance of caution, we have notified affected customers. There is currently no evidence of data misuse, and our systems remain fully operational. Protecting patient data is our highest priority, and we are working closely with cybersecurity experts and legal counsel. We will provide updates as more information becomes available.



Why This Approach Works

- Confirms the incident without speculating on numbers
- Matches what customers already know
- Demonstrates responsibility and professionalism
- Avoids legal risk while maintaining credibility
- Aligns with SCCT's rebuild and corrective action strategy

This approach reduces reputational damage while preserving trust with customers, regulators, and the public.

4.1 Media Response Statement

HealthConnect Media Response Statement

HealthConnect is currently investigating a cybersecurity incident involving unauthorized access to a portion of our production environment. The activity was identified by our security monitoring systems early Monday morning, and we immediately activated our incident response protocols.

Our initial investigation indicates that an external actor gained access using compromised API credentials and queried patient record data over a limited period of time. The affected systems were secured promptly, the vulnerability was remediated, and the credentials involved were revoked. Importantly, our platform remains operational, and we continue to monitor our environment closely.

At this stage, the investigation is ongoing, and we are working with leading third-party cybersecurity forensic experts to determine the scope and impact of the incident. While our analysis is still underway, the data involved may include patient demographic and clinical information. There is currently no confirmed evidence that data was exfiltrated



or misused; however, we are treating this matter with the utmost seriousness and urgency.

HealthConnect has notified law enforcement and is coordinating closely with legal and regulatory experts to ensure full compliance with all applicable federal and state requirements, including HIPAA. We will notify affected customers and individuals directly as soon as we have verified information that allows us to provide accurate and meaningful guidance.

We recognize the trust that healthcare providers and patients place in us to protect sensitive health information. Safeguarding data is a core responsibility, and we regret the concern this situation may cause. We are committed to transparency, accountability, and taking all necessary steps to strengthen our security controls and prevent similar incidents in the future.

As this is an active investigation, we will share updates as more facts become available. In the meantime, our priority remains protecting patient information and supporting our customers.

4.2 Media Relations Strategy Memo

To: Chief Executive Officer

From: Vice President of Communications

Subject: Media Relations Strategy – Response to Healthcare IT News Inquiry

Date: Day 1 – Monday, 2:45 PM

1. Purpose of This Memo

This memo outlines the recommended media relations strategy in response to the inquiry from Healthcare IT News regarding the HealthConnect data breach. The objective is to manage media coverage proactively, maintain credibility, comply with legal obligations, and protect long-term stakeholder trust while the investigation remains ongoing.



2. Decision to Confirm the Breach

It is recommended that HealthConnect confirm the existence of the data breach rather than declining to comment.

Rationale:

- The breach has already been disclosed to affected customers, increasing the likelihood of media leaks.
- Declining to comment would appear evasive and undermine trust.
- Transparency aligns with HIPAA requirements and crisis communication best practices.
- Early confirmation allows HealthConnect to frame the narrative accurately rather than reacting to speculation.

3. Information Disclosed vs. Withheld

Information to Disclose:

- Confirmation of unauthorized access to the HealthConnect platform.
- Approximate number of affected patient records (noting that the investigation is ongoing).
- Type of data involved at a high level (PHI).
- Immediate actions taken (containment, credential revocation, forensic investigation).
- Commitment to notifying affected parties and regulators.

Information to Withhold:

- Technical details that could compromise security.
- Attribution of fault to specific individuals or customers.
- Definitive statements on regulatory violations or penalties.
- Speculative conclusions while forensic analysis is ongoing.

This balance ensures transparency without increasing legal or operational risk.



4. SCCT Response Strategy Application

Consistent with SCCT guidance for preventable crises, HealthConnect should adopt a rebuild strategy:

- Acknowledge responsibility for protecting patient data.
- Express empathy for affected individuals
- Communicate corrective actions.
- Avoid denial or minimization.

The media statement should emphasize accountability and corrective action without making admissions of negligence.

5. Positioning for Ongoing Media Coverage

By confirming the breach and providing verified facts early:

- HealthConnect establishes itself as a credible and responsible source.
- Media narratives are less likely to rely on speculation or anonymous sources.
- The company is positioned as cooperative, transparent, and patient-focused.

This approach supports sustained, balanced coverage as the situation evolves.

6. Risks and Benefits of the Approach

Benefits:

- Preserves organizational credibility.
- Reduces misinformation and rumor escalation.
- Aligns with regulatory and ethical expectations.
- Demonstrates leadership and maturity in crisis management.

Risks:

- Short-term negative media attention.
- Increased scrutiny from regulators and investors.

**Mitigation:**

- Consistent messaging across all channels.
- Close coordination with Legal and Security teams.
- Regular updates as facts are confirmed.

7. Proactive Media Recommendations

At this stage, proactive media outreach should be limited.

Recommendations:

- Respond only to confirmed media inquiries with approved statements.
- Designate a single spokesperson (VP of Communications).
- Prepare holding statements for additional outlets.
- Reassess proactive engagement after regulatory notifications are complete.

8. Conclusion

Confirming the breach with a carefully crafted statement is the most responsible and strategic approach. Transparency, empathy, and consistency will help HealthConnect manage reputational risk while demonstrating accountability and commitment to affected stakeholders.

5.1 Social Media Response Strategy

Element	Strategy/Decision	Rationale
Response to Specific Patient Tweet	Immediate, empathetic, but private response. Do not confirm the patient's identity or medical status publicly.	Public confirmation of the diagnosis would violate HIPAA and further breach the patient's privacy. The goal is to acknowledge the pain and immediately transition to a private, secure communication



		channel for resolution (e.g., direct message) to offer support and specific remediation.
General Company Statement	Post a single, consistent, company statement across all platforms (Twitter, Facebook, LinkedIn). This statement should be posted within 30 minutes.	This takes control of the narrative, shows the company is active, and directs users to a central source of accurate information (likely the website). It reinforces the core messages of accountability and action taken.
Managing High Volume of Negative Mentions	Employ a 'Triage and Redirect' strategy.	The Social Media Manager cannot respond to every negative comment. Focus resources on: 1. Responding privately to genuinely affected patients who need specific help (like the patient in the Inject). 2. Responding publicly to reputable media inquiries, redirecting them to the Media Response Statement. 3. Redirecting general angry/speculative users to the official company statement/FAQ on the website.



Guidelines for Individual Comments	Strict adherence to core messages: 1. Do not speculate or contradict the official statement. 2. Do not engage in arguments or defensiveness. 3. Use pre-approved holding statement templates (e.g., "We sincerely apologize for the anxiety this incident has caused. Our official statement and resources are available here: [Link]"). 4. Never discuss customer or patient-specific details.	Ensures message consistency and prevents the Social Media Manager from inadvertently increasing legal liability or privacy risk.
Monitoring and Tracking	Elevate monitoring to real-time (24/7 coverage). Track key metrics: Volume (mentions/hour), Sentiment (positive/neutral/negative), Key Influencers (media/industry experts), and Geographic Spread.	High volume (800% increase) requires dedicated resources. Tracking sentiment is critical for determining if the response strategy is working or if a new action is required.

5.2 Social Media Posts

Response to the Patient's Tweet (Twitter)

@ConcernedPatient, we are deeply sorry and hear your pain. The emotional and personal impact of this incident is unacceptable. Please check your direct messages. We want to connect you immediately with a dedicated support team member to address your specific situation with the utmost privacy and confidentiality. Your well-being is our priority.

➤ General Company Statement (Twitter)



@HealthConnect, we sincerely apologize for the unacceptable security incident impacting our patients and customers. We are taking full responsibility. The unauthorized access has been contained, and we are working around the clock with forensic experts to understand the full scope. Affected customers are being notified directly. We are here for you. For official information and updates, please visit our dedicated statement page: [Link to HealthConnect Security Update Page] #DataSecurity #Accountability

Facebook Post (For Company Page)

HealthConnect Official Statement

To Our Patients and Customers:

We sincerely apologize for the recent security incident that has caused significant concern and anxiety. We know the trust you place in us to protect your sensitive health information is paramount, and we have failed to uphold that trust in this instance. This is unacceptable.

An unauthorized party gained access to a portion of our database, and we have confirmed that patient records were accessed. The incident has been contained, the vulnerability is patched, and we have launched a comprehensive investigation with leading third-party forensic experts.

Our Commitment to You:

- We are taking full responsibility and apologize unreservedly.
- We are notifying all affected healthcare provider customers directly today.
- We are working diligently to determine the exact scope of affected individuals and will be providing identity theft protection and support services.
- We will be completely transparent in our recovery and remediation efforts.

We will update this page regularly. We are focused on supporting our customers and patients through this, and we will earn back your trust.



[Link to HealthConnect Security Update Page]

- LinkedIn Post (For Company Page)

HealthConnect CEO Statement

As CEO of HealthConnect, I want to address the recent security incident directly. They express profound sorrow and acknowledge accountability for the breach of Protected Health Information (PHI).

Our immediate focus is on full containment, transparency, and supporting every affected individual and provider. We are implementing enhanced security protocols and cooperating fully with law enforcement and regulators.

This is a sobering moment for HealthConnect, and we are committed to moving forward with integrity, learning from this experience, and dedicating the necessary resources to ensure this does not happen again. Our commitment to the future of healthcare technology and the security of data remains absolute.

Find our official statement and regular updates here: [Link to HealthConnect Security Update Page]

#HealthConnect #Security #CrisisManagement

6.1 Strategic Communication Memo

MEMORANDUM

Crisis Communication and Stakeholder Management

Compiled by: Group 4

Date: 15 January 2026



To: Executive Team (CEO, CFO, General Counsel, and CISO)

From: Vice President of Communication

Date: January 12, 2026

Subject: Recommended Strategic Approach to Crisis Communication: Balancing Business Protection with Transparency and Accountability.

Purpose

This memo provides guidance on balancing the competing priorities raised in today's discussion, specifically, protecting critical business interest such as contract renewals while maintaining the transparency and accountability essential for long-term reputational recovery following the confirmed data breach affecting 127,000 patients' records.

1. The current situation presents a clear tension, Short-term business protection versus long-term trust restoration. The CFOs concerns about revenue at risk (\$6million in pending renewals) and the \$30 million Series D round are valid and urgent. However, any attempt to downplay the breach's severity will almost certainly erode trust further when the full impact scope becomes public.

The most effective balance is to lead with accountability and empathy while framing our response actions as evidence of organizational strength and commitment. This approach protects business relationships by demonstrating that HealthConnect is a responsible partner that detects, responds to, and learns from incidents promptly. These qualities ultimately strengthen rather than weaken customer and investor confidence.2. Guidance from Situational Crisis Communication Theory (SCCT)

Under SCCT, this incident falls into the preventable crisis cluster due to evidence of organizational responsibility (Compromised API credentials that were not adequately



protected, allowing unauthorized access and exfiltration of PHI). Preventable crises carry high attributability of responsibility to the organization and therefore require rebuilding strategies. The recommended rebuild strategies include:

Apology: Express regret for the incident and its impact on patients and customers.

Compensation: Offering tangible remediation such as two years of credit monitoring, identity theft protection for affected individuals, and dedicated support resources for customers.

Remediation: clearly outlining corrective actions already taken and future enhancements.

SCCT explicitly warns against diminishing or denial strategies in preventable crisis, as these increase reputational damage when stakeholders perceive the organization as evading responsibility. Our communication must therefore prioritize rebuilding postures while avoiding any language that could be interpreted as minimization.

3. Risks of minimizing vs Risk of Over-Apologizing

The risks of minimizing, such as overemphasizing rapid detection or lack of patient care disruption, include:

- Perceived lack of empathy and accountability, fueling negative media and social media sentiments.
- Backlash from regulators, patients, and customers who feel the human impact is being downplayed.
- Long-term erosion of trust that could jeopardize renewals, funding, and the planned IPO.
- Potential legal/reputation magnification if future disclosures contradict minimized framing.

The risks of over-apologizing, such as showing excessive remorse or admissions of systemic failure includes:



- Increased legal exposure by implying negligence that could be used in litigation.
- Unnecessary alarm among stakeholders, potentially accelerating customer fear or investor concerns.

The optimal path is measured by accountability. Acknowledge the seriousness and our responsibility without speculative or overly emotional language, while pivoting quickly to concrete response and remediation actions.

4. Communicating Accountability without Increasing Legal Liability.

All communications must be reviewed by the General Counsel before release. Recommended principles include:

- Use expressive accountability – Use of statements such as “We deeply regret that this incident occurred and are committed to supporting those affected”.
- Avoid admission of fault – Do not use phrases such as “we failed to”, “negligence”, or “our security was inadequate”.
- Focus on Facts and forward actions – Emphasize what we know and what we have done, such as “vulnerabilities were patched, credentials revoked”, and what we are offering (credit monitoring, enhanced security measures).
- Frame shared responsibility carefully – Note that the breach originated via compromised customer-managed API credentials, only if legally cleared and in a non-accusatory manner, such as “we are working with affected customers to review credential management practices”.

5. Recommendations for Investor Communication

The following are the recommendations for investor communication:



- Timing – Communicate proactively within the first 24 hours after the incident, before rumors spread.
- Channel – Personalized emails from the CEO to the lead investor, followed by a call to discuss.
- Tone and content – Transparent summary of the incident, current status, response actions, and early assessment of business impact. Emphasize proactive detection, containment, and remediation as evidence of mature governance, which are qualities attractive to public-market investors. Reaffirm commitment to the IPO timeline while noting that we are monitoring impacts. Invite questions to demonstrate openness.
- Goal – Maintain confidence by showing strong crisis leadership rather than hiding or minimizing the issue.

6. Recommendations for At-Risk Customer Communication

The following are the recommendations for at-risk customer communication:

- Timing – Immediate personalized outreach (phone call from CEO/Account Executives) to the three customers in renewal negotiations, followed by a written summary.
- Approach – Acknowledge their likely concerns, express regret for the incident, provide specific exposure details, outline dedicated support resources, and highlight remediation investments. Offer enhanced security reviews or contract concessions (if approved) as compensation gestures.
- Messaging - Reinforce partnership value and our commitment to earning continued trust through actions, not just words. Avoid defensiveness, focus on collaboration to protect shared patients.

7. Maintaining Employee Morale

- Employees are currently managing high stress while handling external questions. To sustain morale the following are the recommendations:



- Continue frequent, honest updates.
- Acknowledge their hard work explicitly in every communication.
- Provide clear guidance on handling inquiries and reassurance that leadership is united in protecting both patients and the company.
- Reinforce that rapid detection and response reflect the team's strength, not failure.
- Offer support resources such as EAP access for those experiencing anxiety.

Conclusion

By adopting a rebuild- focused strategy rooted in measured transparency, genuine empathy, and decisive action, we can protect critical business interests while positioning HealthConnect for reputational recovery. Attempting to minimize the incident will almost certainly produce an undesired outcome. I recommend we align on this approach immediately and proceed with proactive investor and at-risk customer outreach tomorrow morning.

Respectively

Vice President of Communication.

6.2 Investor Communication

From: Chief Executive Officer, HealthConnect

To: Mr. Timothy Brown

Subject: Security Incident and Business Impact Update

Dear Mr. Timothy Brown,

I am writing to provide a transparent update regarding a recent cybersecurity incident detected on the HealthConnect platform and to highlight the business implications and on-going efforts.

Our security monitoring systems identified unauthorized access to a production database, earlier this week, resulting from compromised API credentials. Upon discovery , we immediately



contained the incident by deactivating the affected credentials, patching the vulnerability, and engaging external cybersecurity and forensic experts.

The investigation has confirmed that a total number of 127,000 patient records associated with 243 healthcare provider customers was affected; however, limited data exfiltration occurred. All systems remained operational throughout the incident, and there was no disruption to patient care or platform availability.

It is the responsibility of HealthConnect to protect sensitive health information. We regret the concern this incident has caused and take full responsibility for managing its impact appropriately. Our response has been swift, executive-led, and focused on transparency, compliance, and long-term trust preservation.

From a business and governance perspective, we have taken the following actions:

- **Regulatory compliance:** We are fulfilling all HIPAA and state-level breach notification obligations and are cooperating fully with regulators under the guidance of external legal counsel.
- **Customer and patient support:** We have notified all affected customers with details of the incident, provided credit monitoring and identity protection services.
- **Security remediation:** We have optimized security, by strengthening credential management, expanded monitoring, and an independent review of our security controls and risk management practices.
- **Executive oversight:** The executive team is managing this, with daily briefings to ensure consistency, speed, and accountability.

We are actively monitoring commercial impact. While one large customer has terminated its contract, the majority of affected customers remain engaged, and several have expressed appreciation for our direct communication and transparency. At this stage, we do not anticipate a material impact on operations, though we remain realistic and vigilant regarding near-term business risk.



I recognize the sensitivity of this development given upcoming growth and funding milestones. However, I am confident that our response, clear accountability, and demonstrated leadership position will enable HealthConnect to navigate this challenge and reinforce long-term investor and customer trust.

I welcome the opportunity to discuss this further and answer any questions you may have. Thank you for your continued partnership and support.

Sincerely,

[CEO Name]

Chief Executive Officer

HealthConnect

7.1 Press Release: (HIPAA Media Notification)

For Immediate Release

HealthConnect Announces Data Breach Incident

Boston, MA – (Day 2 Date) – HealthConnect, a healthcare technology company providing cloud-based electronic health record (EHR) services, announced today that it has discovered and is actively responding to a data breach affecting certain patient records. The organization is taking immediate action to notify affected individuals and mitigate any potential impact.

What Happened: On (Day 1 date), we identified evidence of unauthorized access to our production environment through compromised API credentials. Upon detection, the company immediately secured affected systems, revoked the compromised credentials, and launched an investigation with the assistance of external cybersecurity and forensic experts.

Data Affected: The investigation determined that an unauthorized third party accessed and downloaded data from a patient records database. Approximately 127,000 patient records associated with certain healthcare provider customers were affected. The information involved



may have included patient names, dates of birth, Social Security numbers, addresses, contact information, medical record numbers, diagnoses, and treatment information.

Our Response:

- We have contained the incident, secured our systems, and taken steps to prevent further unauthorized access.
- Engaged independent cybersecurity and forensic experts to conduct a thorough investigation to determine the full scope of the incident.
 - We are notifying all affected individuals and regulatory authorities as required by law.
 - We are implementing additional security measures to strengthen our defenses.
 - Arranged for two years of complimentary credit monitoring and identity protection services for affected patients.

“Our responsibility to protect patient information is something we take extremely seriously,” said [CEO Name], Chief Executive Officer of HealthConnect. “We deeply regret the concern this incident may cause patients and our healthcare providers. We are committed to transparency, supporting those affected, and strengthening our safeguards to reduce the risk of this happening again.”

Information for Affected Individuals: All affected individuals will receive a notification letter with additional information and resources. HealthConnect has established a dedicated support line and website to assist patients with questions.

HealthConnect remains committed to maintaining the highest standards of patient privacy and data security. We apologize for any concern this incident may cause and are taking all necessary measures to prevent recurrence.

For more information, individuals may visit the (incident website) or call the (toll-free number).



Media Contact:

Communications Team

HealthConnect

Email: media@healthconnect.com

7.2 Patient Notification Letter

Breach Notification for Affected Customers - (Day 2 date)

To: Affected Customers

Subject: Important Security Notice - HealthConnect

Dear Valued Customer,

We are writing to inform you of a security incident involving HealthConnect that may have affected your personal health information. We understand how important the privacy of your information is, and we sincerely regret this situation.

What Happened: On (Date), we identified unauthorized access to our production database. We immediately took steps to stop the activity and launched an investigation with the help of cybersecurity specialists. The investigation determined that an unauthorized individual accessed and downloaded certain patient records.

What Information Was Affected: The information involved may have included your:

- Name and contact information.
- Date of birth.
- Social Security number (SSN).
- Medical record number
- Diagnosis and treatment information.



What We Are Doing: As soon as we learned of this incident,

- We have contained the incident, secured our systems, and taken steps to prevent further unauthorized access.
- We have engaged external cybersecurity experts.
- We have notified healthcare providers and regulators.
- We are notifying all affected individuals.
- We are implementing additional security measures to prevent similar incidents in the future.
- We are offering all affected individuals two years of complimentary credit monitoring and identity theft protection services through (Credit Monitoring Company Name).

What You Should Do:

1. Monitor your accounts for any unauthorized activity.
2. Consider placing a fraud alert or credit freeze with the credit bureaus.
3. Review your account statements regularly.
4. Contact us if you notice any suspicious activity

Additional Resources:

- (Link to FAQ page)
- (Link to credit monitoring offer)
- (Contact information for questions)

We sincerely apologize for this incident and any inconvenience it may cause. Your trust is important to us, and we are committed to protecting your information. If you have questions or would like assistance, please contact our dedicated support line at (toll-free number), or visit (incident website) for more information.

Sincerely,

HealthConnect's Security Team.

Crisis Communication and Stakeholder Management

Complied by: Group 4

Date: 15 January 2026



8.1 Crisis Response Memo

From: Vice President of Communications

To: CEO, Health Connect

Subject: Communication Strategy Following Customer Defection Announcement

Date: Day 2, 2:00 PM

Situation Overview

Due to the recent data breach, our biggest client decided to openly terminate their relationship. Due to this development, the problem has escalated from a data security event to one involving market confidence and trust. There is a greater chance of more defections because other clients are now looking for assurance and direction.

Even if the breach was caused in part by the client's internal security procedures, how we react going forward will have a significant impact on stakeholder trust, customer retention, and Health Connect's long-term reputation.

1. Should Health Connect respond publicly to the Customer's Press Release?

Yes, but cautiously and without conflict.

Health Connect should respond to the public in a measured, values-based manner that:

- Respectfully acknowledges the customer's decision.
- Reaffirms our accountability and commitment to patient data protection.
- Refrains from getting involved in a public argument or placing blame.

The response shouldn't aggressively defend our security posture or specifically refute the customer's claims. A defensive stance would probably prolong media attention and strengthen unfavorable opinions.

Recommended approach:

A brief public statement that shifts attention to further repair and customer partnership while highlighting regret, accountability, and corrective action.



2. Should Health Connect Point Out the Customer's Failures?

No. not publicly

Even though the customer's poor safeguarding of API credentials is a true contributing factor, bringing this out in public would:

- Look defensive and retaliatory
- Undermine our message of accountability
- Indicate to other customers that Health Connect may transfer blame under duress.

In legal or contractual contexts, these matters may be factually and discreetly discussed if needed, but not in communications that are visible to the public.

3. How Should Health Connect Communicate with Other At-Risk Customers?

Proactive, straightforward, and sympathetic contact should be our top focus. This includes:

- A CEO-led communication to all remaining clients
Executive leadership and Customer Success personally reach out to high-level and vulnerable accounts
Clearly stated customer service, security improvements, and remedial procedures

The following should be emphasized in messaging:

- Transparency without conjecture
- Partnership rather than transactions
- Our long-term dedication to gaining and regaining confidence



4. Market Signal and Recommendation Response

The market is strongly informed by the customer defection that security events have serious economic repercussions and that trust is brittle.

In response, Health Connect has to:

- Show leadership rather than defensiveness
- Stress that we are accepting responsibility and learning from the incident.
- Show that we are bolstering rather than weakening our security posture.

The market will evaluate us more on our response than on the fact that a customer departed.

5. Appropriate SCCT Response Strategy

This situation still qualifies as a crisis that could have been avoided and has a high attribution of culpability.

The suggested approach under SCCT is still:

Rebuilding strategy: apology, responsibility, and remedial action

Supporting factors: reiterate principles, dedication to clients, and sustained enhancements.

Reputational harm would be greatly increased by denial or diminishing tactics (such as placing the blame on the client).

6. Risks and Benefits of Different Approaches

Approach	Benefits	Risks
Defensive / Blame-Shifting	Short-term emotional relief	Escalates conflict, damages trust, fuels media cycle



Silence	Avoids immediate headlines	Creates perception of avoidance or guilt
Measured Accountability (Recommended)	Preserves credibility, reassures customers, aligns with SCCT	Requires restraint and discipline

Recommendation

We should respond publicly with empathy and accountability, avoid public blame, and immediately reassure remaining customers through transparent, CEO-led communication. This approach best protects Health Connect's credibility, customer relationships, and long-term market position.

8.2 Customer Retention Communication**Email from the CEO to All Remaining Customers**

Dear Valued Health Connect Partner,

In light of the security problem we revealed earlier this week, I would like to personally address recent developments.

One of our clients has decided to stop their contract and switch to a different provider, as you may have noticed. We acknowledge the issues this presents for you and your company, and we appreciate their choice. The trust you have in us is based on protecting patient data, and when that trust is betrayed, it should be openly and honestly acknowledged.

I want to be clear first and foremost: we are accountable for this situation. We acknowledge the impact this breach has had on our clients, their patients, and their trust in us, even if the inquiry is still ongoing.

We have taken prompt, decisive action since discovering the situation, such as:

Crisis Communication and Stakeholder Management

Compiled by: Group 4

Date: 15 January 2026



- Revoking compromised credentials and closing the identified access pathway
- Conducting a full forensic investigation with third-party security experts
- Accelerating security enhancements across authentication, monitoring, and access controls
- Expanding internal security reviews and customer-facing safeguards
- Providing affected organizations and patients with support and identity protection services

Security is a continuous collaboration rather than a one-time commitment. In order to guarantee shared accountability, more precise security requirements, and more robust safeguards throughout all integrations, we are improving the way we collaborate with clients.

We think clients should continue to have faith in Health Connect because:

- We acted quickly to contain and investigate the incident
- We have been transparent, even when the information was difficult
- We are investing significantly in security improvements beyond baseline compliance
- We remain fully committed to supporting you, your teams, and your patients

I also want to stress how important communication is to us. We greatly value your inquiries, worries, and comments. Our Customer Success and leadership teams are available to have direct conversations with you, go over our remediation efforts, and talk about how we can best assist your company going forward.

It takes deeds, not words, to earn trust. Even while we are aware that trust cannot be restored quickly, we are dedicated to working with you in an honest, responsible, and cooperative manner.

Thank you for your continued engagement and for holding us to the highest standards.

Sincerely,

Crisis Communication and Stakeholder Management

Complied by: Group 4

Date: 15 January 2026



Chief Executive Officer

Health Connect

Decision Point 9: Employee Town Hall (Day 2, 4:00 PM)

You're hosting an all-hands employee town hall via video conference to address the crisis. Employee morale is low. Some employees are worried about job security given the customer defection. Others are frustrated that they're receiving hostile comments from friends and family about working for a company that "leaked medical records."

The CEO will provide an update on the incident and response. You need to prepare talking points for the CEO and be ready to answer employee questions.

9.1 CEO Town Hall Talking Points

TO: CEO

FROM: VP of Communications

DATE: Day 2, 4.00 PM

SUBJECT: Talking Points for All-Hands Employee Town Hall

Opening

"Good afternoon, team. Thank you all for being here. I know the last two days have been among the hardest many of you have experienced at HealthConnect. Before we begin, I want to acknowledge and express my gratitude for your commitment during this time of inconvenience, anxiety, stress, and even embarrassment. I understand that some of you are worried about your jobs, while others may be struggling to discuss recent events at home or in your communities. I am deeply grateful to all of you, as I have witnessed everyone performing at their best during this challenging crisis for our company. This is why I am here to speak to you directly in honesty and respectfully, not through headlines or rumors."

Incident Summary & Current Status

Crisis Communication and Stakeholder Management

Compiled by: Group 4

Date: 15 January 2026

**Summary**

Late Sunday night, our security systems detected unauthorized access to our production database using compromised API credentials, and our team contained the breach within four hours. The investigation has confirmed that approximately 127,000 patient records were accessed, the data included highly sensitive PHI, and there is no evidence that financial or payment information was accessed. Data from 243 of our 850 healthcare provider customers was accessed. We have personally notified every affected customer.

Immediate Response

- The activity was detected through our security monitoring tool, and we swiftly activated our incident response plan.
- We revoked the compromised credentials and patched vulnerabilities.
- We engaged a leading third-party cybersecurity and forensic expert to conduct a thorough investigation.
- We have preserved the evidence and began fulfilling our legal obligations by notifying regulators and affected customers yesterday, and patients.
- We have established a dedicated call center and are offering two years of complimentary credit monitoring and identity protection services to every affected individual.

Current Status

The incident has been contained, and our systems are secure and functioning normally. While the forensic investigation is ongoing, we have confirmed that there is no unauthorized access currently taking place. Our core systems are operational, and we are in the process of notifying customers, patients, and regulators. The investigation will continue to validate our findings and identify any necessary improvements. There is no active compromise at this time.

What We've Learned & What We're Doing Differently**Key Lessons**

Crisis Communication and Stakeholder Management

Complied by: Group 4

Date: 15 January 2026



- Credential-based attacks are one of the most common risks in healthcare
- Compliance is no longer merely a checklist; continuous monitoring must be enforced, and controls should be implemented for ongoing improvement and adaptation to emerging threats.
- Ensure that the right rules and policies are set up for effective monitoring.
- Carry out audits regularly to ensure the necessary controls are effective.

Actions Already Taken

This incident represents a failure in our systems and processes to safeguard entrusted data, and we take full responsibility. We are taking concrete steps to ensure:

- Immediate access and credential hardening
- We have updated our configuration policies for logging and real-time anomaly detection and deployed additional real-time intrusion detection and data exfiltration monitoring tools.
- Security reviews for affected integrations are already ongoing and we have engaged a top-tier cybersecurity firm to conduct a comprehensive security audit; their findings will be public, and we will act on every recommendation, and there will be executive-level oversight of remediation.

Further Actions

- We will enforce stronger API authentication requirements
- Continuous credential validation
- Independent third-party security assessment biannually
- Approve and purchase SIEM tools for automated monitoring for faster detection.
- Improve on our security programs and awareness training
- Improve and update our IR and BC/DR table top exercises, playbooks, and drills.
- Carry out frequent audits for control effectiveness.

Business Impact & Outlook

**What Has Happened**

- We have lost a major customer, which represents a significant portion of our annual income. We understand that this is a considerable financial and reputational setback for us.
- We are in conversations with other concerned customers as they are seeking clarity. Some are uneasy, and we are working tirelessly to rebuild their trust.
- The HHS Office for Civil Rights has announced an investigation, which we will cooperate with fully, and this may result in financial penalties.
- We want you to understand that this will have a short-term impact on our revenue.

Implications

We are not currently contemplating any layoffs. We are focused on building resilience and serving our customers. The best thing every single one of us can do for our job security is to deliver exceptional services in our different fields to support our customers. This does not imply that the company is unstable or that our mission has changed.

The Executive Team is focused on:

- Retaining customer trust through direct engagement
- Supporting patients and providers
- Maintaining operational and financial stability
- Making smart, not reactive, decisions

Employees Appreciation

I want to take a moment to acknowledge the incredible resolve you have all demonstrated in the face of external challenges over the past few days. Your unwavering commitment, dedication, and integrity these past days have been nothing short of remarkable. You are not just working for HealthConnect; you are actively defending its mission and our customers during this critical time. The professionalism and tenacity you bring, especially when facing outside criticism and hostility, are the very foundation of our recovery. We see your efforts, we thank you, and we are proud to stand beside you as we work to rebuild trust and emerge from this incident even stronger. I especially thank the:



- IR and BC/DR teams for their swift response
- Security and engineering teams working around the clock
- Customer Success handling difficult conversations
- Support teams dealing with emotional calls
- Communications, Legal, and Operations teams that are under intense scrutiny
- Commitment to Transparency & Accountability

Our commitment to transparency and accountability is how we rebuild broken trust.

Accountability Means

- Executive ownership, including myself
- Cooperation with regulators
- External audit of our improvements and controls
- Clear communication, even when uncomfortable

Accountability Does NOT Mean

- Blaming individuals or teams
- Blaming customers
- Hiding behind legal and technical jargon
- Downplaying the harm caused
- This is our new baseline. We will earn back trust through consistent, responsible behavior, starting with how we lead through this incident.

Vision for Moving Forward

Where do we go from here? Our vision remains unchanged: to transform healthcare through technology that providers and patients can trust. But today, 'trust' has a new, deeper meaning for us. Our goals are as follows:

Short-Term

- Complete investigations
- Support patients and customers
- Stabilize trust

**Mid-Term**

- Implement and validate security improvements
- Strengthen customer partnerships
- Restore confidence externally

Long-Term

- Become a model for transparent incident response
- Lead conversations about healthcare security responsibility
- Build a robust GRC program.

Handling Difficult Questions**Guidance for Live Q&A**

- Let the employee finish their question without interruption.
- Acknowledge Emotion and be empathetic: e.g “I understand why you'd ask that, it's a real concern.”
- Be direct and answer the question asked. Be comfortable with replying “we don’t know yet” and commit to finding out.
- Stick to facts and committed plans. Avoid speculations.
- Refer to Subject Matter Experts when the need arises.

Closing

Team, this is our moment of trial. I am confident we will meet it because of your commitment and tenacity. I am asking for your continued focus, your ideas, and your resilience. We will keep communicating, keep improving, and keep showing up the right way. Thank you for engagements and for holding us to a high standard.”



9.2 Anticipated Q&A

Are we going to have layoffs because of this?

At the current stage, there have been no plans for layoffs that are connected to the incident. HealthConnect is fiscally sound, business as usual, with high customer demand for our service.

Our current priority is to:

- Assistance to Affected Customers & Patients
- Improving our security posture
- Cooperating Fully with Regulators
- Continuing Operations

Although the issue of data breaches is serious and costly, the management is committed to mitigating the effects responsibly without overburdening the employees. If the change in the operating environment of the company were to occur, the management would communicate clearly. We think that the solution to the issue is to retain our employees and work towards regaining trust.

Why didn't our security prevent this?

HealthConnect has made extensive investments in security, compliance, and audit processes, ranging from keeping up to date with HIPAA compliance to being SOC 2 Type II compliant. But no technology is foolproof when it comes to attacks that are highly sophisticated, especially those that involve credential attacks and evolving threat tactics.

What matters most now is how we respond:

- The problem exists, but it has been remedied



- Credentials that have been compromised have been revoked
- Further monitoring and controls will be introduced
- Independent forensic and security experts are hired

This event has been treated more as a learning experience to enhance defenses and minimize risks further. Security is the joint responsibility of the firm and the company has kept itself open for improvement rather than casting blame.

What if more customers leave?

Customer trust is a serious business, and management is taking this seriously. At the same time, customers realize that a crisis incident is as important as a business's reaction to that incident.

HealthConnect is:

- Proactive and transparent customer communication
- Giving advice and assistance to the providers
- Enhancing our commitment towards security and compliance
- Increasing expenditures on improvement opportunities directly benefiting customers

Although some degree of customer loss may be expected, the point here is to keep the trust using accountability, empathy, and follow-through. This can also be accomplished by employees being professional, informed, and reliable in their interactions.

How should I respond when people criticize HealthConnect?

Employees are not expected to represent the company or participate in discussions. If asked or challenged, say:

Be polite and composed

- Don't guess or spread rumors or unsubstantiated claims



- Please refer others to statements and updates through HealthConnect.
- Do not share opinions or internal information on social media.

A safe answer is:

“HealthConnect has acknowledged the incident and is actively working with experts and regulators. Official updates are available on our website.”

If there are media queries, consumer escalations, or concerning mails, kindly direct them to the Communications or Legal Department. Accuracy and consistency must be maintained during this stage.

Will executives be held accountable?

Yes. Accountability is an integral part of the leadership principles at HealthConnect.

The executive team and the board are:

- Observation of the incident management process in action
- Review of Safety Governance, Policies, and Controls
- Cooperating fully with regulatory inquiries
- Dedicated to improvement in those areas that have gaps identified.

Accountability does not include jumping to conclusions before completing an investigation. It involves taking responsibility, learning from what has been discovered, and following through on actions. Leadership knows that their best way to build trust is through action, not words.

Is our IPO plan still on track?

It is also a long-range strategic plan for the IPO, but it is difficult to say what its effect on this plan is.

Currently, it focuses on:

Crisis Communication and Stakeholder Management

Compiled by: Group 4

Date: 15 January 2026



- Handle the Incident Responsibly
- Ensure legal compliance
- Strong Governance & Risk Management

How we manage those circumstances will be closely scrutinized by both investment and regulatory bodies. Integrity in our management of the circumstances will serve to engender confidence in our leadership here at HealthConnect.

What happens if we get fined by regulators?

Regulatory investigations often occur as a regular course of events following a protected health information incident. It does not necessarily follow that if there is an investigation, there will be fines.

If penalties had been imposed:

- They would be dealt with at a corporate level
- The company has finances and insurance in place to deal with risks like this.
- Business continuity plans are in effect to reduce operational impact

Workers should not have to fear worst-case scenarios. The company has been fully cooperating and has committed to providing compliance and a commitment to protecting patient information.

Should I be looking for another job?

Neither is there any expectation that the workers will resign because of this incident.

Crises are tough times, but they are also defining moments. How HealthConnect meets the ethical, transparency, and responsibility challenge will define the future for the firm. Their leadership believes in the value of employees and knows that at this point, stability, teamwork, and professionalism are the key.



If you do experience anxiety, managers and HR are there to support you. Questions and concerns are legitimate, and we do encourage open discussion.

Decision Point 10: Regulatory Investigation Announcement (Day 3, 10:00 AM)

The Department of Health and Human Services Office for Civil Rights has announced it is opening a formal investigation into HealthConnect's HIPAA compliance. The announcement is public and includes this statement:

"OCR is investigating whether HealthConnect, Inc. failed to implement adequate safeguards to protect electronic protected health information as required by the HIPAA Security Rule. This investigation will examine the company's security practices, risk analysis, and compliance with HIPAA requirements."

This is now a major news story. Reporters are calling, asking if HealthConnect violated HIPAA and what penalties the company might face (HIPAA violations can result in fines up to \$1.5 million per violation).

10.1 Public Statement on Investigation

HealthConnect media statement for immediate release.

HealthConnect's Public Statement

Boston, Monday, 2026 – HealthConnect acknowledges that the U.S. Department of Health and Human Services Office for Civil Rights (OCR) has opened a formal investigation into our HIPAA compliance.

The security and privacy of our customers' information is our highest priority. We are fully committed to cooperating with OCR throughout its review and to providing complete transparency regarding our security practices and controls.



We have a robust HIPAA compliance program in place, including regular risk assessments, SOC 2 Type II certification, and ongoing security audits. Our team continues to strengthen our security measures to ensure the protection of electronic protected health information (ePHI) for the millions of patients whose data we manage.

HealthConnect takes this opportunity seriously and remains confident in the effectiveness of our compliance and security programs. We are actively working with all relevant stakeholders to support the investigation and to reinforce best-in-class practices for safeguarding health information.

Resources for customers and partners.

Customers with questions about their data or our security practices can contact us at **people@healthconnect.org** or call **0703 44X XXXX**.

Media Contact

[Name]

Vice President of Communications

Phone: 0702 23XXXX

Email: vic@healthconnect.org

To: All HealthConnect Employees

Subject: Important Update: OCR Investigation

Dear Team,

We would like to notify you that a formal investigation into HealthConnect's HIPAA compliance has been launched by the Office for Civil Rights (OCR) of the U.S. Department of Health and Human Services. When a business's security procedures are examined to make sure they adhere



to federal regulations for safeguarding electronic protected health information (ePHI), this routine regulatory procedure takes place.

What This Means:

The investigation will review our security practices, risk assessments, and compliance with HIPAA requirements.

OCR may request documentation, conduct interviews, and review our policies and procedures.

This is a regulatory review and does not imply that any violation has been confirmed.

How This Affects HealthConnect and Employees:

- Our operations will continue as normal. There is no immediate impact on your day-to-day work.
- It is critical that we maintain our focus on serving our customers and patients, as their trust is our top priority.
- We may provide information to OCR or other authorities as requested, in coordination with the legal and compliance teams.

Employee Guidance:

- Avoid making assumptions or sharing information about the investigation with others outside the organisation, such as friends, family, or social media.
- For external enquiries, please contact the Communications team at 0703 44X XXXX or send them to our official statement at people@healthconnect.org.
- Keep up with all security procedures and report any strange activity right once.



We want to assure you that HealthConnect has a strong compliance and security program, and we are cooperating fully with the investigation. If you have questions, please reach out to your manager or the Internal Communications team at **internalcomms@healthconnect.org**.

Thank you for your attention and commitment.

[Name]

vice president of communications

HealthConnect

11.1 Communication Strategy Memo

MEMORANDUM

TO: Chief Executive Officer, HealthConnect

FROM: Vice President of Communications

DATE: Wednesday, Day 3, 2:30 PM

SUBJECT: Strategy for Communicating Recovery and Positive Developments

Executive Summary: As we move past the immediate crisis response phase, we have received positive indicators regarding customer retention and industry recognition of our transparency. However, publicizing these developments requires extreme caution. We must shift the narrative from "Crisis" to "Recovery and Learning" without appearing to minimize the severity of the breach or the impact on patients.



Recommendation on Speaking Invitation Recommendation: We should accept the invitation but frame the announcement carefully.

Rationale: The invitation to speak on "Learning from Security Incidents: Building Trust through Transparency" validates our decision to prioritize accountability over defensiveness. However, we should not issue a standalone press release about this, as it may be perceived as celebratory while patients are still receiving breach notifications.

Execution: Instead, we should weave this into a broader "Path Forward" blog post. The framing should be altruistic: We are sharing our painful lessons to help the broader healthcare ecosystem secure patient data, not to garner accolades.

Recommendation on Customer Retention Recommendation: We should not publicly announce specific customer wins/retention at this time.

Rationale: While two major customers deciding to stay is excellent news, announcing this publicly risks looking desperate or tone-deaf. It may also inadvertently invite the media to interview those customers, putting them in an awkward position regarding their security standards.

Execution: We should use this data in aggregate form during the Board meeting and internal employee communications to boost morale. Externally, we can express general gratitude for the "continued partnership of our healthcare providers" without citing specific turnaround stories.

Shifting the Narrative: From Crisis to Recovery.

To shift the narrative without minimizing the breach, we must adhere to the following principles:

- **Validation, not Victory:** We cannot claim "victory" over a breach that exposed patient data. We can only claim progress in remediation.



- **Focus on the Future:** Communications should pivot from "what happened" to "what is changing."
- **Humble Confidence:** We must project confidence in our new security measures while maintaining humility regarding the failure that occurred.

SCCT Framework Application: Bolstering According to Situational Crisis Communication Theory (SCCT), we are transitioning from Rebuild strategies (apology, compensation) to Bolstering strategies.

- **Bolstering Approach:** We can now remind stakeholders of our past good works and our current commitment to industry leadership.
- **Caution:** Bolstering is a secondary strategy. It effectively repairs reputation only if the primary Rebuild strategy (the apology and credit monitoring offer) was accepted. If we bolster too early, stakeholders will view it as "spin".

Timing Considerations

- **Immediate:** Internal communication regarding customer retention to stabilize employee morale.
- **Day 3 (End of Day):** "Path Forward" Blog Post (see deliverable 11.2).
- **Next Week:** Detailed technical breakdown of the security improvements (after the OCR investigation scope is fully defined).



11.2 Recovery Communication

Format: Corporate Blog Post| **Author:** CEO of HealthConnect|**Title:** A Hard Lesson: Our Commitment to a More Secure Future

To our Patients, Customers, and Partners,

The past 72 hours have been the most challenging in HealthConnect's history. As we have shared previously, we discovered a vulnerability that allowed unauthorized access to patient records. We have taken full responsibility for this incident, and I want to reiterate my deepest apologies to the patients and providers affected.

However, an apology is only meaningful if it is followed by action and change.

Today, I want to share where we go from here. The immediate threat has been neutralized, and we are cooperating fully with the Department of Health and Human Services. But "back to normal" is not our goal. Our goal is a new standard of security that exceeds every requirement.

Learning through Transparency, we chose to be transparent about this incident from the moment it was confirmed, despite the business risks. We did this because trust is the currency of healthcare. We believe that hiding the details of security failures only helps attackers.

In that spirit, I have accepted an invitation to share our findings and lessons learned at the upcoming Healthcare Industry Association annual conference. I will be speaking candidly about where we fell short and the specific frameworks we are implementing to ensure it does not happen again. We hope that by sharing our "scars," we can help other healthcare technology providers protect their patients better.

The Road Ahead We are heartened that, after reviewing our remediation plans and security roadmap, the vast majority of our provider partners have chosen to continue their journey with us. We do not take this trust for granted; we intend to re-earn it every single day.



We are moving forward with humility, but also with resolve. We will be better. We will be safer. And we will continue to serve the healthcare community with the technology it deserves.

Sincerely,

[CEO Name] CEO, HealthConnect

12.1 Crisis Communication After-Action Report

CRISIS COMMUNICATION AFTER-ACTION REPORT (AAR)

Incident: Data Breach / Unauthorized API Access

Date: Wednesday, Day 3

Prepared By: VP of Communications

1. **.Executive Summary & Timeline:** HealthConnect experienced a significant data breach affecting 127,000 patient records. The crisis spanned 72 hours of high-intensity response, involving customer defection, regulatory scrutiny, and media pressure.

Day 1: Discovery, Employee Notification, Customer Notification, Social Media escalation.

Day 2: Regulatory Notification (HHS/State AGs), Customer Defection Crisis, Employee Town Hall.

Day 3: Regulatory Investigation (OCR), Shift to Recovery/Bolstering.

2. What Went Well (Strengths)

- **Employee-First Strategy:** Prioritizing the 420 employees for notification before external releases created a unified front. The Town Hall helped stabilize morale during the customer defection crisis.



- **SCCT Application:** Adopting a "Rebuild" strategy (Apology + Compensation) rather than "Diminish" or "Deny" likely prevented a mass exodus of customers. The decision to reject the "spin" requested by the CFO preserved our long-term credibility.
- **Speed of Initial Response:** We successfully met the 15-20-60-90-minute crisis timeline for initial assessments, allowing us to control the narrative before the reporter from Healthcare IT News published their story.

3. What Could Be Improved (Weaknesses)

- **Social Media Monitoring Latency:** We were slow to detect the viral tweet regarding the HIV diagnosis disclosure. By the time we responded, mentions had increased 800%. A real-time sentiment analysis tool should have flagged this immediately.
- **Sales vs. Communications Alignment:** The tension between the need for transparency and the pending \$6M contract renewals created internal friction. Sales leadership needs to be better integrated into crisis simulation training to understand why transparency is legally and reputationally required.
- **Customer Communication Granularity:** While we notified customers quickly, the "Customer Defection" highlighted that our initial messaging may not have sufficiently armed our customers to speak to *their* patients, leading to panic at the regional hospital system.

4. Lessons Learned

- **Transparency mitigates long-term damage:** While admitting the breach caused immediate stock/customer pain, the transparency regarding the "API credentials" allowed technical teams at client sites to verify the fix, eventually leading to customers staying.



- **The "Victim" aspect of SCCT:** Because this was a "Preventable" crisis, we had to accept full blame. Any attempt to shift blame to customers (as suggested by the CEO regarding customer security practices) would have been disastrous.
- **Empathy is a business metric:** The specific response to the patient with the HIV diagnosis was a turning point. Generic corporate speak fails on social media; human empathy de-escalates viral sentiment.

5. Recommendations

- **Implement 24/7 Social Listening Tools:** Deploy enterprise-grade monitoring (e.g., Brandwatch or Sprout Social) with automated alerts for keywords like "leak," "records," and "HealthConnect."
- **Dark Site Development:** Pre-build a "Crisis Response" web portal that can be activated in 15 minutes, containing templates for press releases, customer FAQs, and patient letters.
- **Cross-Functional Tabletop Exercises:** Conduct quarterly simulations involving Legal, Sales, and Tech to practice the friction points experienced on Day 1 (Sales vs. Legal).
- **Media Training for Executives:** While the CEO handled the Town Hall well, the initial impulse to be defensive about customer security failures suggests a need for coaching on "bridging" techniques during high-stress moments.

12.2 Board Presentation Outline

PRESENTATION TO THE BOARD OF DIRECTORS: CRISIS RESPONSE & RESILIENCE STRATEGY

Slide 1: Title Slide

Title: Incident Response Review: API Data Breach

Presenter: VP of Communications



Goal: Review impact, response effectiveness, and future investments.

Slide 2: The Incident by the Numbers

- **Scope:** 127,000 Patient Records accessed.
- **Duration:** 4-hour window of vulnerability; 72-hour intense crisis cycle.
- **Impact:** 243 Customers affected. 1 major customer loss (\$850k ARR).
- **Regulatory:** OCR Investigation is active.

Slide 3: Communication Response Strategy

- **Framework:** Applied Situational Crisis Communication Theory (SCCT).
- **Strategy:** "Rebuild" (Full apology + Remediation) due to "Preventable" crisis type.
- **Execution:**
 - Prioritized Employee notification (Day 1).
 - Transparent Customer notification before public leaks (Day 1).
 - Cooperation with regulators (Day 2/3).

Slide 4: Critical Decision Points & Outcomes

- **The Pivot:** Choosing transparency over the CFO's request to "minimize" the incident.
 - *Result:* Retained 2 major at-risk customers who cited "honesty" as a factor.
- **The Media:** Managing the Healthcare IT News Leak.
 - *Result:* Controlled the narrative rather than letting rumors define the story.
- **Social Media:** The HIV Patient Tweet.
 - *Result:* Initial delay, followed by empathetic response. Highlighted the need for better monitoring tools.

Slide 5: Business Impact Assessment

- **Reputation:** Short-term hit, but signs of recovery (CEO conference invite).



- **Financial:** Loss of \$850k ARR (Regional Hospital). Retention of \$5M+ in other at-risk contracts.
- **Legal:** Investigation ongoing; potential fines up to \$1.5M.

Slide 6: Path Forward & Investment Ask

- **Objective:** Move from "Reactive" to "Resilient."
- **Investment Request:**
 - \$50k for real-time social sentiment monitoring software.
 - \$25k for quarterly crisis simulation drills for the Executive Team.
 - Resources to build a "Dark Site" crisis portal.

Conclusion: Transparency was painful but saved the company. We must now operationalize these lessons.

References

Coombs, W. T. (2007). Protecting organization reputations during a crisis: The development and application of situational crisis communication theory. *Corporate Reputation Review*, 10(3), 163–176. <https://doi.org/10.1057/palgrave.crr.1550052>

Health Insurance Portability and Accountability Act of 1996, Pub. L. No. 104-191, 110 Stat. 1936 (1996). <https://www.govinfo.gov/app/details/PLAW-104publ191>

National Institute of Standards and Technology. (2012). *Computer security incident handling guide* (Special Publication 800-61 Revision 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>